

# Hospital Data Access — Roles, Professions, and Best-Practice Access Models

**Purpose:** an exhaustive, standards-grounded catalog of who gets access to what patient data in a hospital, and on what basis — the role side of the T0-T3 sensitivity taxonomy already built for Patient360. This is what a real Gate configuration would be parameterized against.

**Grounding:** HIPAA Privacy/Security Rule (minimum necessary + access control, 45 CFR §164.312/164.502), the HL7 Role-Based Access Control Healthcare Permission Catalog (built on the ASTM E1986 licensed/non-licensed personnel framework), and GDPR Article 9 (health data as special-category, processed under the healthcare-provision basis with a professional-secrecy obligation) — the EU-side equivalent relevant to a Geneva-based product. Swiss nFADP mirrors the GDPR structure closely enough that the same access logic applies.

---

## Part 1 — The governing frameworks, briefly

- **HIPAA minimum necessary + RBAC.** Covered entities must identify, per role, exactly which PHI that role needs to do its job, and configure systems so access defaults to that scope — not to "everything, unless restricted." Hospitals typically define 20+ roles; small practices fewer than 10.
  - **HL7 RBAC Healthcare Permission Catalog.** A standardized vocabulary of (operation, object) permissions — e.g., Order Entry, Review Documentation, Perform Documentation, Scheduling — built from real clinical task scenarios rather than invented abstractly. It explicitly separates roles into licensed providers, non-licensed providers, and non-ASTM (non-clinical) categories, and flags certain data — adoption records, HIV results, mental health visits — as warranting access constraints regardless of the requester's general role.
  - **GDPR Article 9.** Health data is special-category and processing is prohibited by default; hospitals rely on Article 9(2)(h) (healthcare provision) combined with Article 9(3), which requires the processing to be done by, or under the responsibility of, someone bound by professional secrecy. This ties access directly to professional confidentiality obligations, not just system permissions — the legal basis for access is the clinical relationship itself.
  - **Break-glass / emergency access** is a formal, separately governed exception path — not a workaround for imperfect RBAC. It exists precisely because minimum-necessary access will sometimes be wrong in a genuine emergency, and the fix is logging and post-hoc review, not broader default access.
-

## Part 2 — Exhaustive role catalog

### A. Physicians & advanced practice — typically T2 ceiling for their own patients

- **Attending physician / consultant** — full clinical record access for patients under their care; typically the broadest routine access tier
- **Resident / registrar / fellow** — access scoped to supervising attending's patients, often with attending co-sign required on orders/notes
- **Hospitalist** — full access to inpatients under their coordination
- **Medical student / intern** — supervised, often read-access plus limited documentation rights, always attributable and reviewable
- **Physician assistant (PA)** — diagnostic/therapeutic access under physician supervision, similar scope to a resident
- **Nurse practitioner (NP)** — advanced clinical access, often equivalent to attending-level for their assigned patients

### B. Nursing & direct clinical support — T1-T2, scoped to current assignment

- **Registered nurse (RN)** — full clinical access to currently assigned patients only, not the whole ward's census by default
- **Charge nurse / nurse unit manager** — ward-level access for staffing/oversight, not necessarily full clinical detail on every chart
- **Clinical nurse specialist / consultant / educator** — access scoped to their consulting role, not a blanket clinical role
- **Triage / ED nurse** — rapid-access profile prioritizing safety-critical fields (allergies, current meds, prior visits) over full history
- **Case manager (RN)** — discharge planning and care-coordination scoped access, often includes payer-facing summary generation
- **Certified nursing assistant (CNA) / healthcare assistant** — task-scoped: vitals, ADLs, not full chart or clinical notes
- **Licensed/enrolled practical nurse** — supervised scope, similar constraint pattern to CNA but with more clinical task access

### C. Pharmacy — T1-T2

- **Clinical pharmacist** — medication list, allergies, and labs relevant to dosing/interactions; often rounds with the care team
- **Pharmacy technician** — dispensing-scoped access, not general clinical notes

### D. Diagnostics & allied clinical — T1-T2

- **Radiologist / radiology technician** — imaging plus the specific order/clinical context relevant to interpretation
- **Laboratory staff / pathologist** — lab-order-scoped access

- **Respiratory therapist** — ventilator/respiratory data and directly relevant vitals; can have break-glass-adjacent override rights for medication cabinets/ventilator settings in a crisis
- **Physical / occupational therapist** — functional status and relevant history, not full psychiatric or unrelated specialty notes
- **Dietitian / nutritionist** — nutrition-relevant history and labs
- **Podiatrist** — relevant history/imaging for the referred condition
- **Speech-language pathologist** — relevant assessment history

#### E. Behavioral / psychosocial — T2-T3, the most legally distinct category

- **Psychiatrist / psychologist / therapist** — full access to their own notes; critically, in the US, **psychotherapy notes carry a separate, stricter legal protection than the rest of the medical record** (a distinct HIPAA category with its own authorization requirement) — the closest real-world legal precedent for treating an entire data category as a hard T3, not just a stricter T2
- **Social worker** — psychosocial and discharge-planning access; not automatically granted the full clinical chart
- **Chaplain / pastoral care** — typically patient-initiated and voluntary, minimal formal chart access by design

#### F. Administrative / operational — mostly T0-T1, deliberately excluded from clinical detail

- **Front desk / registration / scheduling** — demographic and appointment-status data only; explicitly not clinical notes
- **Health Information Management (HIM) / medical records department** — the procedural gatekeeper for release-of-information requests, record amendments, and research-access determinations. Broad *reach* but narrowly *purpose-bound* — every access is a logged transaction against a specific request, not ambient browsing
- **Billing / coding staff** — diagnosis codes, procedure codes, treatment dates, provider identity; explicitly **not** the complete clinical narrative (this is one of the clearest, most citable minimum-necessary examples in the literature)
- **Case management / utilization review** — care-coordination and payer-facing scope
- **Quality / patient safety staff** — chart review for incident investigation; scoped to the specific case under review, logged
- **Compliance Officer / Privacy Officer / DPO** — oversight access, typically to audit logs and flagged cases rather than routine full-record browsing — this role audits the Gate, it isn't exempt from it
- **IT / security staff** — system-level infrastructure access; should not casually extend to clinical content, and any content access during maintenance/support needs its own scoped, logged justification (this is explicitly called out as a common failure point — a contractor's access level is often undefined until someone asks)

## G. Emergency / exceptional access — its own governance track

- **Break-glass / emergency override** — pre-staged, individually named accounts (never shared credentials), reason-coded at the moment of use, auto-expiring, triggering a real-time alert to the privacy/security officer, with mandatory post-hoc review within 24-48 hours. This is the formal analog to the "locum coverage" scenario at private-practice scale — same mechanism, hospital-grade frequency and tooling.

## H. Research — access is a legal-basis question, not a role question

- **Principal investigator / study team** — access governed by IRB approval plus either patient authorization, a documented IRB waiver, or use of a properly de-identified/limited dataset
- **De-identified or limited-dataset research** — the single biggest lever for expanding access without expanding the RBAC burden: HIPAA Safe Harbor de-identification (removal of 18 defined identifier types) takes data outside PHI protection entirely; a "limited dataset" (dates and general geography retained, direct identifiers removed) still requires a formal Data Use Agreement
- **Data custodian / database manager** — often the *only* role with re-identification capability; everyone downstream works from de-identified extracts, which is precisely the PMC-Patients-style pattern already in use for the Patient360 demo data

## I. External, legal & oversight access — separate doctrine entirely, worth keeping distinct in any Gate design

- **Patient (self)** — full access to their own designated record set via the formal patient-access channel (portal or records request) — notably, using one's own *workforce* credentials to browse one's own chart is generally treated as a policy violation, because it bypasses the formal access-logging path even though the person is entitled to the data
- **Personal representative / healthcare power of attorney / legal guardian** — once properly authorized, treated as the patient for access purposes; scope follows the authorization, not a blanket rule
- **Parent of a minor** — access can be legally *limited* even for a parent, for specific categories of sensitive care (varies by jurisdiction) — a case where the "requester role" and "patient relationship" don't collapse into simple full access
- **Law enforcement** — narrowly scoped by default (name, address, date of birth, blood type, injury type, treatment/death timing for locating a suspect or witness); anything broader requires a specific legal instrument (subpoena, warrant, or court order) and is handled through a formal legal-response process, not ordinary clinical RBAC
- **Health oversight / regulatory investigators** (e.g., billing-fraud audits) — can have broad access, but it is strictly purpose-bound to the oversight activity, not general browsing

- **External auditors / accreditation surveyors** — process- and documentation-focused, time-boxed engagement, typically no patient-identifiable clinical content needed for most of the audit
  - **Insurers / payers** — claims-relevant data only, governed by contract and the same minimum-necessary standard applied to billing staff
  - **Referral-receiving external providers** — minimum-necessary summary only, under the same Article 9(3)/professional-secrecy chain that governs internal access, not the full source record
- 

### Part 3 — Best-practice principles that cut across every role

1. **Role is necessary but not sufficient — access also has to be scoped to current assignment.** An RN's "role" grants clinical access in general; the *specific* access is to currently assigned patients, not the whole census. This is the HL7 "constraint" concept — cardinality, time-dependency, location — layered on top of the base role.
  2. **Minimum necessary is the default test for every category, including non-clinical ones.** Billing, front desk, and IT all have the same discipline applied, just against different data shapes.
  3. **Some data categories override role entirely.** Psychotherapy notes, HIV status, substance-use treatment, and genetic data attract elevated protection *regardless of who's asking* — this is the real-world legal precedent for treating T3 as its own rule rather than a stricter T2, exactly as flagged in the earlier taxonomy.
  4. **Emergency access is a separate, formal, logged track — never a silent broadening of default access.** Individually attributed, reason-coded, time-boxed, alerted in real time, reviewed after the fact.
  5. **External and legal access follows an entirely different doctrine than clinical RBAC.** Different legal basis (subpoena, court order, oversight authority vs. treatment relationship), different scope, different logging obligation — worth keeping architecturally distinct in a Gate rather than folding "law enforcement" into the same role table as "nurse."
  6. **De-identification is the highest-leverage tool for expanding access without expanding the access-control burden.** This is precisely why PMC-Patients-style already-public/de-identified data is the right demo substrate — it sidesteps this entire access question rather than solving it.
  7. **The record-custodian role (HIM / Privacy Officer / DPO) is not a super-user.** Its access is itself process-bound and logged — the office that audits the Gate is still inside the Gate, which is a genuinely persuasive detail to include in a Patient360 demo.
-

## Part 4 — Mapping onto Patient360's T0-T3 taxonomy

| Role category                                 | Typical tier ceiling         | Gate design note                                                                                                     |
|-----------------------------------------------|------------------------------|----------------------------------------------------------------------------------------------------------------------|
| Attending / treating clinician (own patients) | T3                           | Full access, but only to currently assigned patients — scope by assignment, not by role alone                        |
| Resident / student / trainee                  | T2 (supervised)              | Mirror attending access but require supervising clinician attribution on the audit trail                             |
| Nursing (assigned patients)                   | T2                           | Scoped to current assignment; shift-based expiry                                                                     |
| Allied health (PT/OT/dietitian/etc.)          | T1-T2                        | Scoped to the referral reason, not the full chart                                                                    |
| Behavioral health notes specifically          | T3, own rule                 | Never inherits from a general "clinical staff" grant — its own explicit authorization                                |
| Pharmacy                                      | T1-T2                        | Meds/allergies/relevant labs only                                                                                    |
| HIM / records / compliance                    | T0-T3 (transactional)        | Access is per-request and logged, not ambient — the Gate treats every access as a transaction, same as a clinician's |
| Billing / front desk / scheduling             | T0-T1                        | Hard ceiling — never sees T2/T3 fields regardless of urgency                                                         |
| IT / infrastructure                           | T0 (system-level only)       | No default path to clinical content; any exception is its own logged, scoped grant                                   |
| Break-glass / emergency                       | Full, time-boxed             | Separate mechanism entirely from the role table — logged, alerted, reviewed                                          |
| Research (de-identified)                      | Below T0 (out of PHI scope)  | The De-identification path is the intended route around the whole tiering system, not an exception to it             |
| Research (identified, IRB-governed)           | Matches underlying data tier | Requires its own authorization record, independent of clinical role                                                  |
| Patient / personal representative             | Full, own record only        | Via formal access channel, not workforce credentials                                                                 |

| Role category                   | Typical tier ceiling        | Gate design note                                                                  |
|---------------------------------|-----------------------------|-----------------------------------------------------------------------------------|
| Law enforcement / legal process | Narrow, instrument-specific | Not a role in the clinical RBAC table at all — a separate legal-response workflow |